

Specification review: consolidated report

25 September 2026 · Deployed build aad267b (database 0088) · Fixes from this review in migration 0089 (not yet applied)

61

spec sections reviewed

1,243

database assertions
passed

6 / 6

Playwright smoke tests
passed

4

defects found and fixed
(0089)

1. Verdict

The accounting logic is sound. All three places the books are checked against each other (journal, ledgers and trial balance) agree:

- Every posted journal balances. The database refuses one that doesn't.
- The trial balance nets to zero on a restored copy of production.
- Customer, supplier, cash, bank and stock ledgers tie to their control accounts, except the one known walk-in item in §5.

The GST figures on the new quick bills are right, and each tax head goes to its own account.

This review found four defects. Two were security gaps that would have let a cashier do an accountant's work. All four are fixed in migration 0089 and proven by new tests. **0089 must be applied before cashier accounts are created.**

Where the app now deliberately differs from the written spec:

- Service is billed without job cards.
- Counter sales are value-only.
- Finance is recorded as journals.

These were your instructions of 25 Sep. The report shows their accounting consequences, so they're a conscious choice. Nine smaller items remain open (§5).

RESULT	SECTIONS	MEANING
PASS	45	Implemented and backed by automated tests or a production check
FIXED IN 0089	4	Worked in general, but this review found a defect; now fixed (pending apply)
YOUR DECISION	5	Differs from the written spec on your instruction (§27, §31, §32, §33, and the clay design in §7)
PARTIAL	7	Mostly there; a named piece is missing (see §5)

2. How it was reviewed

METHOD	WHAT IT COVERED	RESULT
--------	-----------------	--------

Playwright: smoke suite (production build on this Mac, live database, read-only)	• App health and database probe. • Every module redirects a signed-out visitor to login. • The login page doesn't reveal whether an e-mail exists. • A password can never reach the URL.	6 of 6 passed
Playwright: every screen, signed in (read-only)	Opens all 94 menu pages and fails on any error page, a 5xx response or an empty render	NOT RUN The login (E2E_EMAIL / E2E_PASSWORD) never reached <code>.env.local</code> ; see §6 for the one-line command.
Playwright: write flows	Creates customers, posts and reverses journals, takes receipts, closes the cash day	NOT RUN, BY DESIGN These write permanent records, so they need a staging database, never live data. The same logic is covered by the database suite below.
Database suite: all 89 migrations on a throwaway PostgreSQL, then 51 test files	• Posting engine, double entry, RLS tenant and branch isolation. • Every business flow. • The audit checklist's sample month (Test A) and its reconciliation, GST and stress tests (B–E). • Role limits.	1,243 assertions passed
Unit tests and static checks	Money arithmetic, parsers, permissions sync, navigation, bundles, schema version, production build	126 tests passed; all checks green
Database probes and code reading, spec §1–§61	• Tables without RLS (none). • Tables without audit triggers. • Functions that post to the ledger without their own permission check. • Policies without a branch check. • GST codes.	4 defects found, fixed in 0089
Production (read-only) and a restore drill	Production dumped, restored locally and compared; 0089 rehearsed on that copy	86 tables identical; trial balance 0.00; 0089 applies cleanly

3. Defects found by this review, now fixed in 0089

FIXED F1: A cashier could post journals through functions that didn't check their permission

Cause. The update of 25 Sep (0088) let the posting engine write journals on behalf of cashier bills and receipts. Before that, the journal table itself had admitted only accounting users. Several functions had silently relied on that and never checked a permission themselves:

- opening balances;
- vehicle sale posting and returns;
- booking refunds.

Impact if not fixed. A cashier calling these directly could post opening balances or a booking refund.

Fix. Every journal now needs a permission that fits its document type:

- a sale needs `sales.post` ;
- a refund needs `bookings.refund` ;
- opening balances or a manual journal need the accountant's permission;
- any type not on the list needs the accountant's permission.

Proof. Test 9ZG: the cashier is refused for six document types, and the accountant is allowed.

FIXED F2: The sale workflow could be self-approved (spec §19, §53)

The sale workflow checked *which* status may follow which, never *who* moves it. Anyone who could create a sale, cashiers included, could move their own sale from Submitted to Accounts Verification to Approved directly and then post it, skipping the accountant. (The weakness predates 0088, but 0088 made the final posting possible.)

Fix. Each step needs its own permission: submit, verify, approve, post, deliver, cancel or return. A salesperson can still recall their own submitted draft.

Proof. Test 9ZG: the cashier can submit and recall, but can't verify or post.

FIXED F3: Quick bills reported every line under the motorcycle HSN (GST)

Each line took its HSN from its GST code. Your GST18 code carries 87112019 (motorcycles and scooters). Labour and water wash are services and need a SAC; spares need 8714. GSTR-1's HSN summary would have listed ₹ of labour as motorcycles.

Fix. Each head has its own HSN/SAC, and the accountant can change them all in Settings. Defaults:

- Spares and Accessories: 8714.
- Labour and Water wash: SAC 998714.

Proof. Test 9ZF, and rehearsed on production data.

FIXED F4: Service history missed bills made without a job card (spec §32)

Service History and the per-customer service summary read only job cards. Every service billed through the new screen would have been invisible there.

Fix. A "visit" is now a job card or a service bill.

Proof. Test 9ZF: both visits are found by vehicle number, and the customer shows 2 visits and ₹1,800.

Also confirmed healthy while probing:

- No tenant table lacks row-level security.
- Price versions can't be edited or deleted once active (§15).
- Cash-day statuses match the spec: OPEN, IN_PROGRESS, COUNTED, CLOSED (§36).
- Bank reconciliation lines use MATCHED, UNMATCHED, PARTIAL or IGNORED, and "matched" requires a link (§39).
- The vehicle stock upload refuses the whole file on any bad row (§14).
- Money is formatted the Indian way (₹1,25,000.00).
- Margin and profit are never sent to a cashier (§10, §52).

4. Section-by-section result

Evidence names refer to the database tests (`supabase/test/`) and migrations. "Screen" items weren't browser-verified; see §2.

§	TOPIC	RESULT	EVIDENCE AND NOTES
1–3	Mission, stack, Railway deployment	PASS	Accounting-first design on one posting engine. Next.js 16, TypeScript, Tailwind, Supabase. Railway deploys on push; env documented; migration bundles and runbooks.
4–5	Multi-tenant, organisation	PASS	RLS on all 86 tables (probe). Dealer and branch isolation: <code>10_rls_isolation</code> , 9ZF (a cashier sees no other branch).
6	Roles and access	FIXED IN 0089	Cashier limited to sales, receipts and payments (0088). Posting and approval gaps closed (F1, F2). Margin hidden from cashier.
7	UI design system	YOUR DECISION	Light claymorphism in place of glassmorphism (Sep 2026); data tables kept flat, per the spec's readability rule.
8	UX principles	PASS	Sticky headers, search-first pickers, confirmations on financial actions, inline validation. Screen check pending (§6).
9	Navigation	PASS	94 menu pages exist (check:nav). Job Cards and HP Sales removed at your instruction; Purchases, HR, Help added.
10	Dashboard	PARTIAL	All 18 mandatory KPIs present; 10 margin and profit KPIs restricted by role. Finance Units and Finance Amount still read finance applications , which are no longer used (O1).
11	Customer master and 360	PASS	Auto customer ID; search by ID, mobile, name, vehicle, chassis; 360 page; quick bills match by mobile or vehicle number (9ZF).
12	Employee master	PARTIAL	Employee IDs mandatory. Quick bills record the <i>user</i> who billed, not an employee ID (O6).
13–14	Vehicle inventory and upload	PASS	Chassis-level stock and status lifecycle; upload validates duplicates, model, branch, cost, invoice, and imports all-or-nothing.
15–17	Pricing, GST master, templates	PASS	Effective-dated immutable price versions with approval (<code>95_price_approval</code>); effective-dated tax codes with categories (0084); invoices keep their own tax.
18	Booking	PASS	Advance to Customer Advances (2100), not revenue (<code>97_booking_advances</code>); refund now needs <code>bookings.refund</code> (F1).
19–20	Sales workflow and invoice components	FIXED IN 0089	Posting only after approval (<code>50_sales_workflow</code>); step permissions added (F2); component lines with HSN and tax.
21–23	One engine, double entry, immutability	PASS	Single posting engine; balance enforced twice; posted journals immutable; correction = reverse + re-post ("Correct" button); Test A sample month exact.
24	Chart of accounts	PASS	66 accounts per dealer, including water wash, consumables, RCM, ITC-reversed, document charges and freight.
25–26	Finance company ledger, trade advance	PASS	One ledger per company (Finance Ledger page, with the other account per line); trade-advance types post to both ledgers (<code>94_finance_operations</code>).

27	Finance / HP tracking	YOUR DECISION	Finance recorded as journals (company Dr / customer Cr, document charges customer Dr), matching your Tally ledger. Approval and disbursement tracking are no longer used (O1).
28–30	Accessories, spares, fitting templates	PASS	LOCAL and COMPANY lots kept separate for purchased stock; fitting templates on vehicle sales.
31	Local-first allocation	YOUR DECISION	Applies to vehicle fittings. Counter and service bills no longer draw stock (O3).
32	Service	YOUR DECISION	No job cards: name, vehicle number, mobile and four values. History fixed (F4).
33	Counter sales	YOUR DECISION	Product name and value only; no stock check or deduction (O3).
34–35	Inventory ledger, branch transfer	PASS	Append-only movements; transfers post through Stock in Transit so each branch balances (9ZB).
36–38	Cash book, day close, bank book	PASS	Opening + receipts – payments = expected; physical count and difference; CLOSED is final; bank book per account (60_cash_and_bank, 9A).
39	Bank reconciliation	PASS	CSV/Excel import with dedupe; matching; BRS with timing items (Test B); "matched" requires a link.
40	GST / e-invoice / e-way bill	PARTIAL	Integration layer, queue, retries and failure isolation built (99, 9V, 9Q). IRP credentials not configured , so nothing is filed yet (O8).
41–43	Reports, price history, consolidated MIS	PASS	Sales, inventory, accounting, GSTR-1/2B/3B with cross-checks, ageing, profitability. Finance reports affected by O1.
44–45	Database design, numbering	PASS	Normalised, with foreign keys and checks; database-issued numbers per dealer and financial year (91_document_numbering).
46	Audit trail	PARTIAL	Documents, masters, prices and approvals audited. Accounting periods, cash accounts, document sequences, finance settlements and e-invoices lack an audit trigger (O4).
47	Security	PARTIAL	RLS, server-side permissions, no service key in the browser, secrets out of Git; F1 and F2 fixed. No rate limiting on sensitive endpoints beyond Supabase's own login limits (O2).
48–50	Atomicity, concurrency, idempotency	PASS	One transaction per business action; row locks on chassis and stock; idempotency keys on every financial endpoint (9L; replay tests in 9ZE, 9ZF).
51–55	Screen standards, sales and verification screens, visuals, errors	PASS	Right-aligned ₹ in Indian format; cost and margin hidden from cashier; clear error messages. §53 accounts verification is enforced by F2 (0089). Screen check pending (§6).
56–58	Development order, rules, traceability	PASS	Every transaction traceable: document → journal → ledger → report; migrations reversible where practical; documentation updated.
59	Definition of done	PARTIAL	Database, RLS, audit, idempotency and reconciliation met. Browser flows and mobile layout are not yet verified (needs the signed-in run and a staging database).
60	25 non-negotiable rules	PARTIAL	22 of 25 met. Rule 7 (employee ID on operational transactions) is partial (O6). Rules 16 and 22 are relaxed for counter and service bills by your decision (O3).

61	First build	PASS	Shell, navigation, dealer and branch context, role-aware menu, dashboard, auth, RLS, audit, migrations.
----	-------------	------	---

5. Open items (not fixed in this review)

#	ITEM	WHY IT MATTERS	RECOMMENDATION
O1	Finance KPIs and reports still read finance applications	With finance now recorded as journals, Finance Units, Finance Amount, penetration and the finance reports will show zero.	Derive them from the finance-company ledger (loans booked against each financier in the period).
O2	No rate limiting on sensitive endpoints (§47)	Supabase limits login attempts, but exports and document downloads aren't throttled.	Add a per-user limit on export and document routes.
O3	Counter and service bills book no cost of sales and move no stock	Spares and accessories stock value stays high, and their margin is overstated, until corrected.	A monthly shelf count and stock adjustment (Inventory → Stock Adjustment); the adjustment posts the cost.
O4	Audit triggers missing on five tables (§46)	Changes to accounting periods, cash accounts, numbering, finance settlements and e-invoices aren't in the audit log.	Add the standard audit trigger to those tables.
O5	No receipt print for vehicle-sale payments	Service, counter and cash-book receipts print; vehicle-sale receipts don't.	Reuse the receipt slip for sale payments.
O6	Quick bills don't carry an employee ID (§12, rule 7)	Staff-wise reports can't attribute counter and service bills.	Take the employee linked to the signed-in user automatically.
O7	Walk-in bill CSI-2026-000001, ₹1,115.10, still unpaid in production	The one open difference on the customer control account.	Record its payment, or post a correcting entry.
O8	E-invoice / e-way bill not connected (§40)	Invoices queue but aren't filed with the IRP.	Add the GSP/IRP credentials when ready.
O9	GST return edges	The first GSTR-3B starts with no carried-forward credit. GSTR-2B is CSV import only, and a non-matching 2B line can't be linked by hand.	Enter any earlier credit balance as a re-claim; add manual 2B linking if needed.

Storage backup. Uploaded attachment files (bills, acknowledgements) aren't in the database backup. Download the Supabase Storage bucket periodically, as the runbook says.

6. What to do next

1. **Apply migration 0089** (`supabase/INCREMENTAL-0089-to-0089.sql`) in the Supabase SQL Editor, then deploy. Do this before creating any cashier login. It closes F1–F4, and it was rehearsed on a copy of production: owner postings, bills, history and the trial balance all correct.
2. **Run the signed-in screen check.** Save `E2E_EMAIL` and `E2E_PASSWORD` in `.env.local`, then run:
`env -u NODE_ENV npx playwright test --project=authed`
It opens all 94 screens read-only and reports any that error. Repeat with a cashier login to confirm the cashier's menu.
3. **Check the new settings.** Settings → GST on service and counter bills: confirm the GST code and HSN/SAC for each head.
4. **Pick up the open items** in this order: O1 (finance KPIs), O3 (monthly stock count), O6, O5, O4, O2.

Prepared from the code and database of the Two-Wheeler Dealer ERP on 25 Sep 2026. Test evidence: `npm run verify` (1,243 database assertions, 126 unit tests, production build), Playwright smoke suite, read-only production checks and a restore drill. The written specification is

